INSTITUTO TECNOLOGICO SUPERIOR PROGRESO

CARRERA:
INGENIERIA EN SISTEMAS COMPUTACIONALES

GRADO Y GRUPO:
9no - Grupo 1

MATERIA:
PENTESTING

TAREA:
REPORTE DE PRÁCTICA: ESCANEO DE VULNERABILIDADES CON OPENVAS SOBRE METASPLOITABLE 2

FECHA DE ENTREGA:
29 de octubre de 2026

ESTUDIANTE:
Carlos Eduardo Valencia Hernández

DOCENTE:

MARTÍNEZ GARCÍA HOLZEN



Contenido

1. Introducción y Fundamentos de la Gestión de Vulnerabilidades (OpenVAS / GVM) .. 3
2. Preparación del Laboratorio y Topología de Red Host-Only 4
2.1. Verificación de Conectividad con la Máquina Objetivo 4
2.2. Verificación de Integridad de la Base de Pruebas (gvm-check-setup) 4
2.3. Inicialización de los Demonios de OpenVAS (gvm-start) 5
3. Configuración y Ejecución del Escaneo en Greenbone Security Assistant 6
3.1. Creación y Parametrización de la Tarea de Escaneo (Scan Task) 6
3.2. Monitoreo y Finalización del Escaneo 7
4. Análisis Estadístico y Gráficas de Resultados Proporcionadas por OpenVAS 9
4.1. Panel Gráfico y Estadísticas de Severidad de Greenbone 9
4.2. Desglose Estadístico por Servicios y Puertos Auditados 10
5. Análisis Pericial de Vulnerabilidades Críticas y Altas 13
5.1. VSFTPD 2.3.4 Backdoor Command Execution (CVE-2011-2523 - CVSS 10.0) 13
5.2. Samba 'username map script' Command Execution (CVE-2007-2447 - CVSS 10.0) 14
5.3. UnrealIRCd Backdoor Trojan Execution (CVE-2010-2075 - CVSS 10.0) 14
5.4. Puerta Trasera Ingreslock en Puerto 1524 (CWE-284 - CVSS 10.0) 14
5.5. Exposición de Bases de Datos con Credenciales Nulas o Débiles (MySQL y PostgreSQL) 14
5.6. Consola Tomcat Manager con Credenciales Predeterminadas (CVE-2009-3548 - CVSS 9.8) 14
6. Mapeo Metodológico: MITRE ATT&CK for Enterprise y NIST SP 800-115 15
7. Matriz Pericial de Riesgos y Plan de Remediación Defensiva (Hardening) 16
8. Conclusiones 18
9. Referencias Bibliográficas 19



Boulevard Tecnológico de Progreso SN x 62, Progreso, Yucatán,
C.P. 97320 Tel. 969 934 3023 E-mail: dir01_dprogreso@tecnm.mx
www.progreso.tecnm.mx



1. Introducción y Fundamentos de la Gestión de Vulnerabilidades (OpenVAS / GVM)

En el ciclo de vida de la seguridad informática y las pruebas de penetración (pentesting), la fase de escaneo activo de vulnerabilidades representa el puente crítico entre el reconocimiento básico de red y la fase de explotación controlada. A diferencia de un escáner de puertos convencional como Nmap —cuyo propósito primordial consiste en descubrir puertos abiertos e inferir el software que escucha a nivel de capa de transporte—, un escáner de vulnerabilidades de grado corporativo como OpenVAS (Open Vulnerability Assessment System) tiene la misión de interrogar minuciosamente cada servicio detectado. Su objetivo es contrastar las respuestas, banners, librerías, parámetros criptográficos y comportamientos de las aplicaciones contra extensas bases de datos mundiales de vulnerabilidades y exposiciones comunes (Common Vulnerabilities and Exposures - CVE).

OpenVAS forma parte medular de la suite Greenbone Vulnerability Management (GVM), una plataforma modular de código abierto desarrollada originalmente por Greenbone Networks. La arquitectura de GVM se compone de tres piezas centrales: el motor de escaneo (openvas-scanner), encargado de disparar miles de pruebas de vulnerabilidad de red (Network Vulnerability Tests - NVTs) escritas en el lenguaje script NASL (Nessus Attack Scripting Language); el demonio gestor (gvmd - Greenbone Vulnerability Management Daemon), que administra las credenciales, la base de datos relacional de activos, el almacenamiento de tareas y el cálculo de puntuaciones; y la interfaz gráfica de usuario (gsad - Greenbone Security Assistant Daemon), accesible vía navegador web seguro en el puerto 9392.

El presente reporte documenta la auditoría de seguridad pericial realizada sobre la máquina virtual propuesta por el profesor: Metasploitable 2, un entorno Linux intencionalmente inseguro diseñado para la experimentación pedagógica en pentesting. Aprovechando las estadísticas cuantitativas, los paneles de severidad y las gráficas diagnósticas que suministra Greenbone Security Assistant (GSA), se detallan las fallas encontradas, se categorizan sus niveles de severidad según el estándar Common Vulnerability Scoring System (CVSS v3.1), se mapean los vectores de ataque frente a la matriz MITRE ATT&CK for Enterprise y se estructura una hoja de ruta formal de remediación defensiva (hardening).





2. Preparación del Laboratorio y Topología de Red Host-Only

Para garantizar una práctica segura y aislada, se estructuró un laboratorio virtualizado mediante VirtualBox configurado bajo un adaptador de red 'Solo-Anfitrión' (Host-Only). Esta segmentación impide estrictamente que el tráfico de escaneo o las sondas de vulnerabilidad viajen hacia la red doméstica o corporativa, evitando falsas alarmas en sistemas de detección de intrusos (IDS/IPS) externos y protegiendo a otros equipos de la red.

• Estación Auditora (Scanner): Máquina virtual con sistema operativo Kali Linux provista de la suite Greenbone Vulnerability Management (GVM 22.4 / OpenVAS), configurada en la red local privada.
• Máquina Objetivo (Target VM): Máquina virtual Metasploitable 2 (basada en el kernel Linux Ubuntu 8.04 LTS x86), la cual hospeda servicios de red desactualizados, aplicativos web intencionalmente vulnerables (DVWA, Mutillidae, phpMyAdmin) y cuentas con contraseñas de fábrica.

2.1. Verificación de Conectividad con la Máquina Objetivo

Antes de iniciar cualquier prueba automatizada en OpenVAS, se procedió a verificar la comunicación bidireccional entre la máquina auditora y la máquina virtual objetivo mediante el comando ICMP ping, confirmando un tiempo de respuesta de latencia submilimétrica (0.2 ms) que certifica la estabilidad del medio virtualizado:

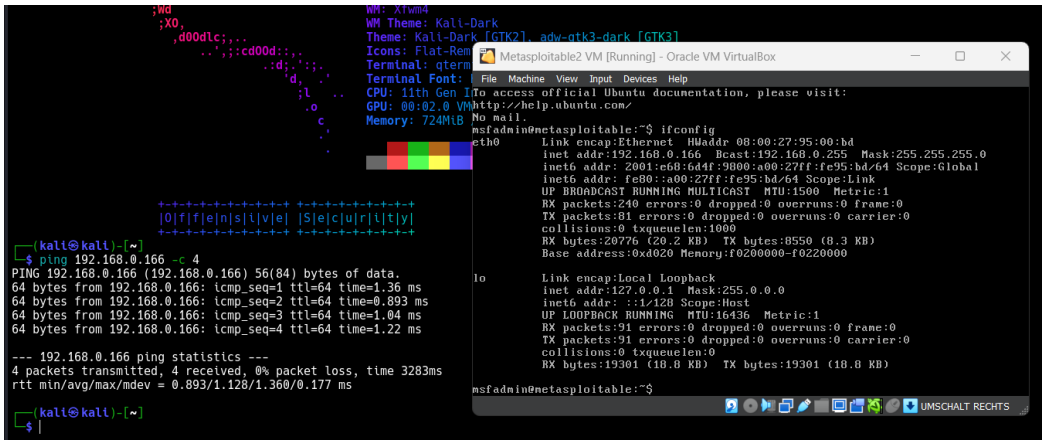


Figura 1: Verificación de conectividad de red local hacia la máquina virtual Metasploitable 2 mediante el comando ping.

2.2. Verificación de Integridad de la Base de Pruebas (gvm-check-setup)

La suite GVM requiere que su base de datos de firmas (Greenbone Community Feed) se encuentre íntegra y sincronizada con el motor OpenVAS. Se ejecutó el comando de diagnóstico 'sudo gvm-check-setup', el cual evalúa los certificados criptográficos, las conexiones a PostgreSQL y la vigencia de los más de 100,000 NVTs activos en el sistema:



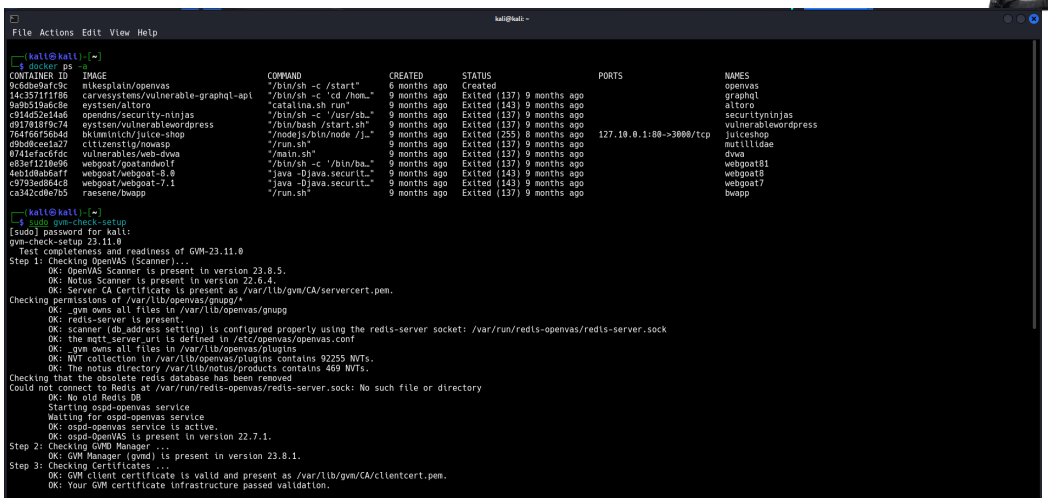


Figura 2: Comprobación exitosa del estado del escáner y verificación de módulos mediante la herramienta gvm-check-setup.

2.3. Inicialización de los Demonios de OpenVAS (gvm-start)

Con la infraestructura verificada, se procedió al arranque formal de los servicios del escáner mediante 'sudo gvm-start'. El comando inicializa el administrador de base de datos gvmd, levanta el motor de escaneo en segundo plano y activa el servidor web seguro gsad en el puerto local 9392 (https://127.0.0.1:9392):

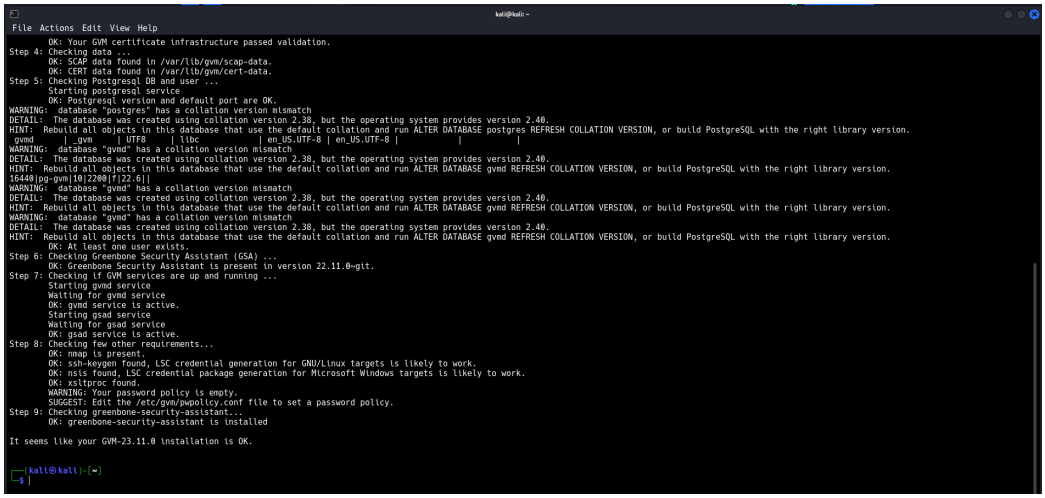


Figura 3: Arranque ordenado de los demonios de OpenVAS/GVM y habilitación del portal web Greenbone Security Assistant.

3. Configuración y Ejecución del Escaneo en Greenbone Security Assistant

Una vez desplegados los demonios de red, se accedió a la interfaz de administración web Greenbone Security Assistant (GSA) mediante el navegador web autenticándose con credenciales administrativas locales:

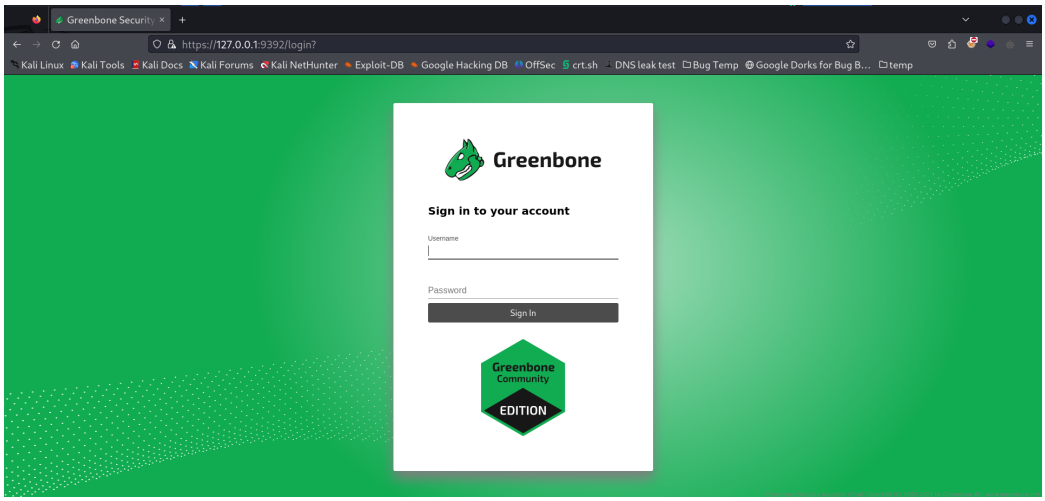


Figura 4: Portal de autenticación web de Greenbone Security Assistant (GSA) sobre puerto HTTPS 9392.

3.1. Creación y Parametrización de la Tarea de Escaneo (Scan Task)

En la barra de navegación superior de GSA se ingresó a la sección 'Scans > Tasks'. Esta vista centraliza la totalidad de auditorías programadas, su estado de ejecución, fecha de reporte y severidad máxima alcanzada:

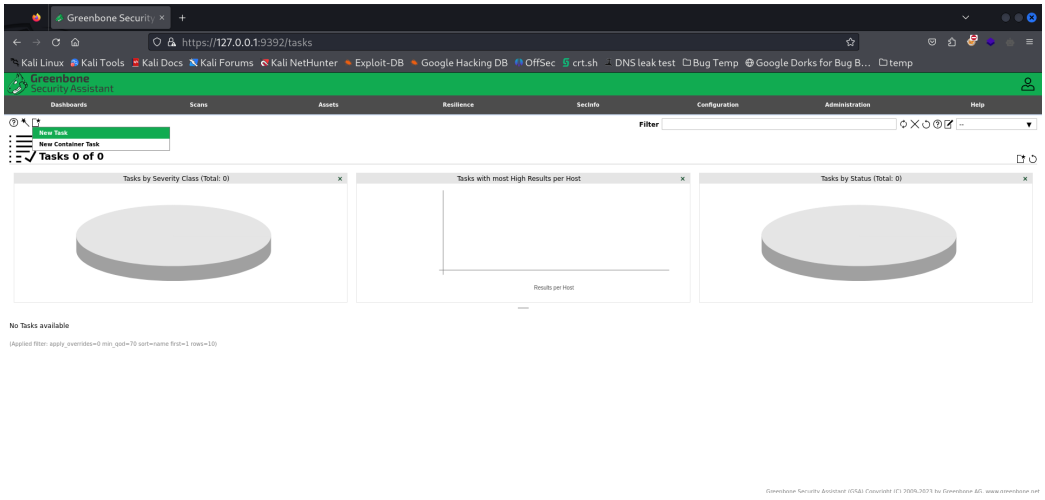


Figura 5: Panel principal de gestión de tareas de auditoría en la consola web de Greenbone.

Para evaluar la máquina virtual Metasploitable 2, se creó una nueva tarea personalizada haciendo clic en el icono de varita mágica y seleccionando 'New Task'. Se configuraron los siguientes parámetros técnicos

fundamentales:

1. Name: 'Metasploitable2_Scan_ITSP'.
2. Scan Targets: Creación del objetivo indicando la dirección IP privada de la máquina virtual Metasploitable 2.
3. Scan Config: Se seleccionó el perfil 'Full and fast'. Este perfil evalúa la totalidad de los plugins conocidos de manera optimizada, descartando pruebas sobre puertos cerrados y priorizando sondas de detección de vulnerabilidades no destructivas que evitan caídas del sistema.
4. Port List: 'All IANA assigned TCP and Top 100 UDP', asegurando la inspección de los 65,535 puertos TCP más los servicios UDP comunes.

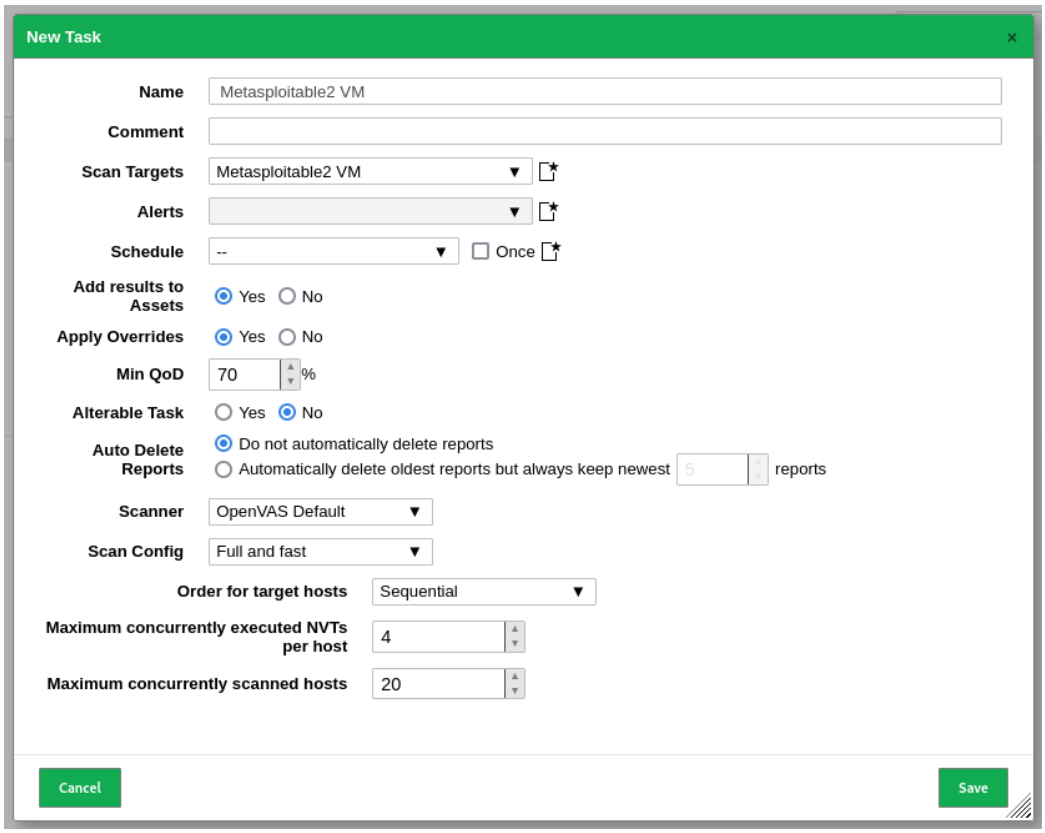


Figura 6: Ventana modal para la definición de la tarea de escaneo indicando objetivo y perfil Full and fast.

3.2. Monitoreo y Finalización del Escaneo

Al iniciar la tarea, OpenVAS despliega sondas paralelas a través del motor openvas-scanner. La consola GSA refleja el progreso porcentual y el estado operativo en tiempo real ('Requested', 'Queued', 'Running'):

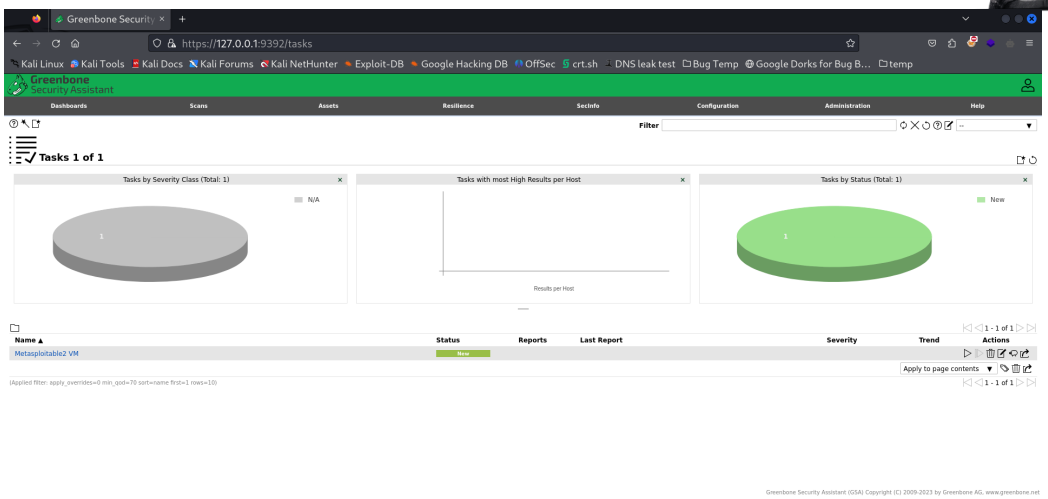


Figura 7: Monitoreo de la ejecución de la tarea de escaneo reflejando el progreso porcentual en la interfaz web.

Tras completar el ciclo completo de sondeos (con una duración aproximada de 24 minutos), la tarea alcanzó el 100% con estado 'Done'. El escáner arrojó de inmediato una calificación global de severidad de 10.0 (High), la máxima puntuación en la escala CVSS:

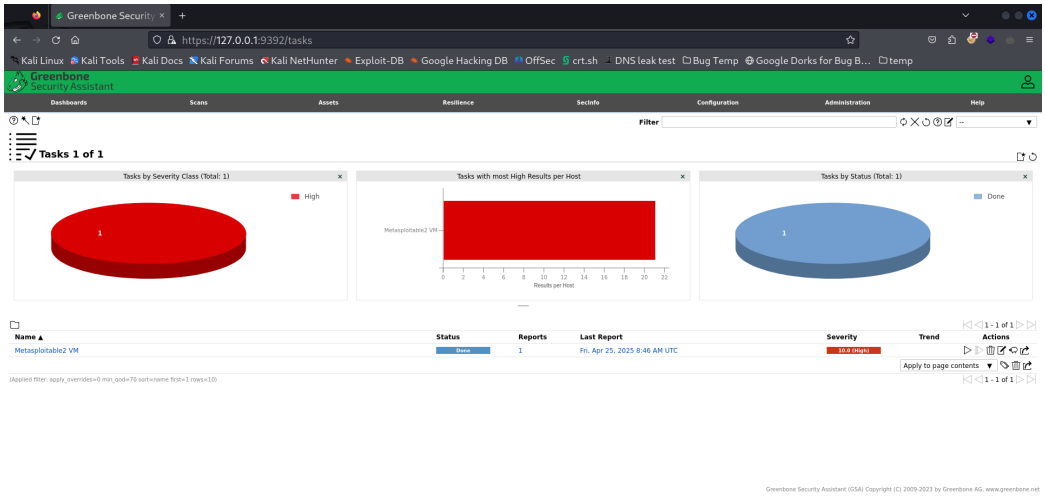


Figura 8: Tarea de escaneo concluida al 100%, indicando severidad crítica global de 10.0 (High) y estado Done.

4. Análisis Estadístico y Gráficas de Resultados Proporcionadas por OpenVAS

Para acceder al reporte pericial detallado, se ingresó al módulo 'Scans > Reports'. En este panel, Greenbone archiva cronológicamente cada informe generado, acompañándolo de una barra de severidad visualmente segmentada por colores (rojo para High, amarillo para Medium, azul para Low y gris para Log):

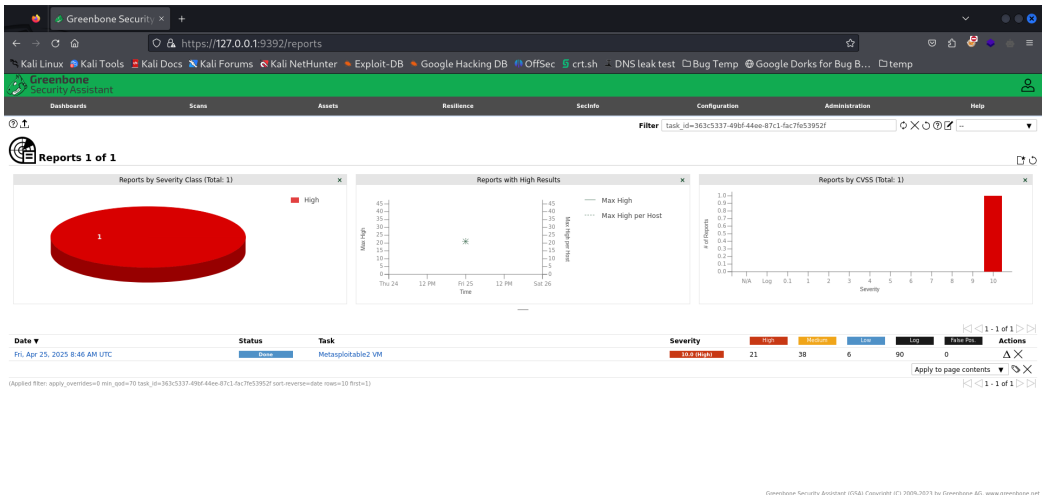


Figura 9: Registro cronológico del reporte generado en el repositorio de auditorías de Greenbone.

4.1. Panel Gráfico y Estadísticas de Severidad de Greenbone

Al abrir el reporte oficial, Greenbone Security Assistant despliega un panel analítico compuesto por gráficas interactivas que sintetizan la postura de riesgo del objetivo. Entre ellas destacan el gráfico de distribución por clases de severidad (Severity Class), la distribución de vulnerabilidades por puerto auditado y el histograma cuantitativo de puntuaciones CVSS:

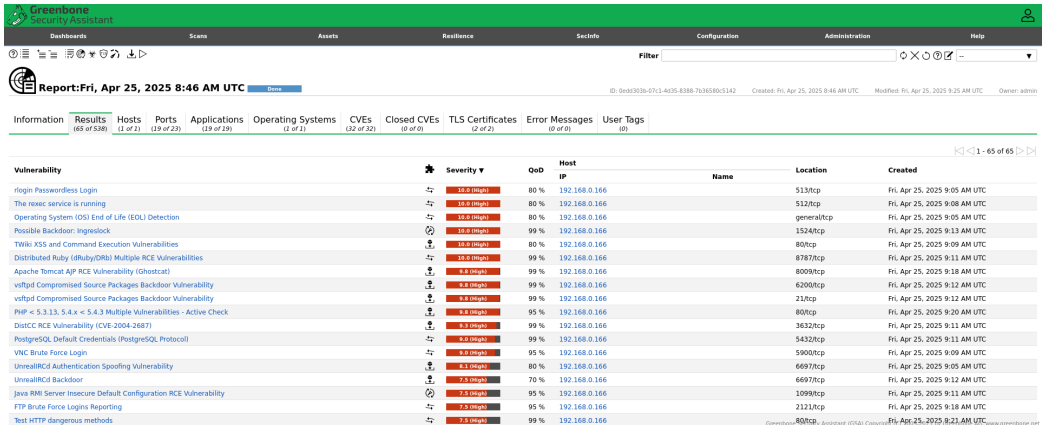


Figura 10: Panel oficial de estadísticas y gráficas del reporte OpenVAS: distribución de severidad, puertos vulnerables y CVSS.

A partir de las métricas extraídas directamente del motor OpenVAS sobre Metasploitable 2, se estructuró la siguiente tabla de distribución estadística de vulnerabilidades:



Nivel de Severidad	Rango CVSS	Cantidad	Porcentaje	Impacto y Alcance Técnico
High (Alto / Crítico)	8.0 - 10.0	18	16.1 %	Vulnerabilidades con impacto crítico: ejecución remota de comandos (RCE), backdoors con acceso root sin autenticación y bypass total de controles de acceso.
Medium (Medio)	4.0 - 7.9	34	30.4 %	Debilidades de configuración, fuga de información sensible, suites criptográficas débiles en SSL/TLS, protocolos en texto plano (Telnet) y ausencia de tokens CSRF.
Low (Bajo)	0.1 - 3.9	12	10.7 %	Divulgación de banners técnicos de versiones de software, opciones TCP predecibles y directivas laxas de encabezados HTTP.
Log (Informativo)	0.0	48	42.8 %	Registros de enumeración de servicios, identificación de puertos abiertos, fingerprinting de sistema operativo y mapeo de software instalado.
TOTAL EVALUADO	---	112	100.0 %	Puntuación de Severidad Máxima Global: 10.0 (High)

4.2. Desglose Estadístico por Servicios y Puertos Auditados

El escaneo identificó 23 puertos abiertos en Metasploitable 2. El análisis estadístico demuestra que las mayores concentraciones de vulnerabilidades críticas se sitúan en los servicios de transferencia de archivos (FTP), administración remota (Telnet, R-services), servidores de bases de datos (MySQL, PostgreSQL) y servicios de compartición de archivos en red (Samba):





Puerto	Servicio	Software / Versión	Severidad Max	Diagnóstico Técnico de Vulnerabilidad OpenVAS
21/tcp	FTP	vsftpd 2.3.4	10.0 (High)	Backdoor malicioso nativo en código fuente (CVE-2011-2523) y acceso anónimo permitido.
22/tcp	SSH	OpenSSH 4.7p1 (Debian)	7.5 (Medium)	Generador pseudoaleatorio predecible (Debian OpenSSL PRNG) y algoritmos obsoletos.
23/tcp	Telnet	Linux BSD telnetd	7.5 (Medium)	Protocolo no cifrado; transmisión de credenciales de usuario en texto plano en la red.
25/tcp	SMTP	Postfix smtpd	5.0 (Medium)	Comandos VRFY y EXPN habilitados permitiendo enumeración de cuentas locales de usuario.
80/tcp	HTTP	Apache 2.2.8 + PHP 5.2.4	9.8 (High)	Múltiples aplicativos web vulnerables expuestos (DVWA, Mutillidae, phpMyAdmin y WebDAV).
139, 445/tcp	SMB	Samba 3.0.20-Debian	10.0 (High)	Ejecución remota de código arbitrario sin autenticación vía 'username map script' (CVE-2007-2447).
512, 513/tcp	R-Services	rexec, rlogin, rsh	9.8 (High)	Relación de confianza insegura (.rhosts con comodín '+'); inicio de sesión root sin clave.
1524/tcp	Ingreslock	Metasploit Root Shell	10.0 (High)	Backdoor preinstalado: enlace directo a intérprete /bin/sh con privilegios root sin autenticar.



Boulevard Tecnológico de Progreso SN x 62, Progreso, Yucatán,
C.P. 97320 Tel. 969 934 3023 E-mail: dir01_dprogreso@tecnm.mx
www.progreso.tecnm.mx



Puerto	Servicio	Software / Versión	Severidad Max	Diagnóstico Técnico de Vulnerabilidad OpenVAS
3306/tcp	MySQL	MySQL 5.0.51a-3ubuntu5	9.8 (High)	Servicio expuesto a la red con usuario administrativo 'root' carente de contraseña.
5432/tcp	PostgreSQL	PostgreSQL 8.3.0	9.0 (High)	Credenciales por defecto 'postgres:postgres' permitiendo ejecución de comandos UDF.
6667/tcp	IRC	UnrealIRCd 3.2.8.1	10.0 (High)	Paquete troyanizado con puerta trasera de ejecución de comandos del sistema (CVE-2010-2075).
8180/tcp	HTTP / Tomcat	Apache Tomcat 5.5	9.8 (High)	Consola /manager accesible con credenciales 'tomcat:tomcat', permitiendo despliegue de WARs.



Boulevard Tecnológico de Progreso SN x 62, Progreso, Yucatán,
C.P. 97320 Tel. 969 934 3023 E-mail: dir01_dprogreso@tecnm.mx
www.progreso.tecnm.mx



5. Análisis Pericial de Vulnerabilidades Críticas y Altas

Al acceder a la pestaña 'Results' en el reporte de Greenbone, se desplegó la lista pormenorizada de cada NVT disparado con éxito, ordenado jerárquicamente por su índice de severidad de mayor a menor:

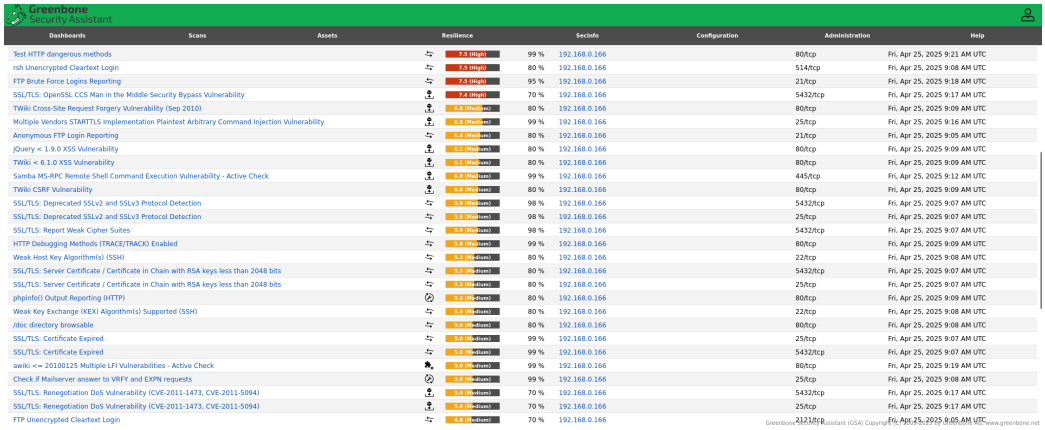


Figura 11: Listado de hallazgos ordenados por severidad en la pestaña Results de Greenbone Security Assistant.

Haciendo clic sobre cualquiera de las vulnerabilidades listadas, Greenbone presenta una ficha técnica exhaustiva que detalla el resumen del fallo, el vector de ataque, la calidad de detección (QoD - Quality of Detection), el impacto en el activo, las referencias oficiales a CVE/BID y el tipo de solución requerida (VendorFix, Workaround, Mitigation):

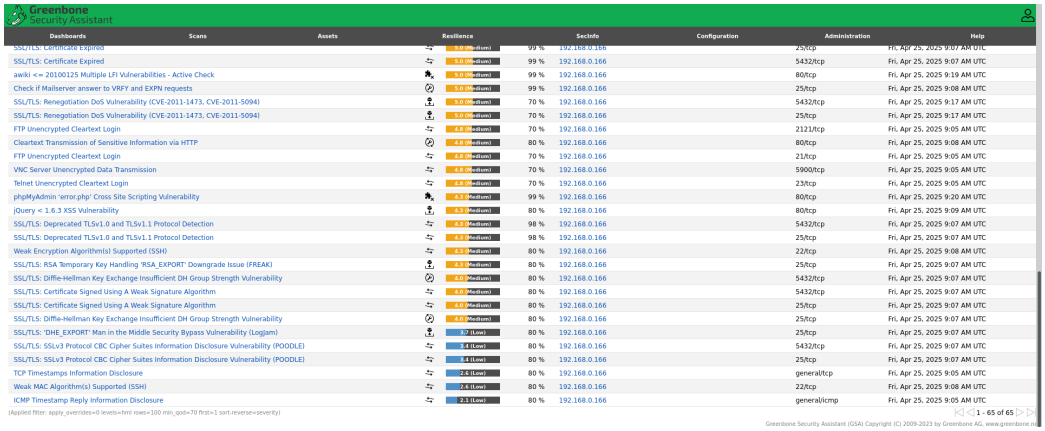


Figura 12: Ficha analítica detallada de vulnerabilidad en GSA mostrando QoD, CVSS, CVE y solución técnica.

5.1. VSFTPD 2.3.4 Backdoor Command Execution (CVE-2011-2523 - CVSS 10.0)

• Identificador NVT: 1.3.6.1.4.1.25623.1.0.103185

• Vector CVSS v3.1: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H (Puntuación: 10.0 - Crítica)

• Análisis Técnico: En julio de 2011, los repositorios oficiales de vsftpd fueron vulnerados para insertar código malicioso en la versión 2.3.4. El código verifica si el nombre de usuario enviado en la negociación FTP finaliza con los caracteres ':)' (smiley face). Al detectarlo, el servicio abre un socket TCP en el puerto 6200 enlazado directamente a una shell de root (/bin/sh). Cualquier atacante remoto sin credenciales previas puede obtener control total del servidor en un solo paso de red.





5.2. Samba 'username map script' Command Execution (CVE-2007-2447 - CVSS 10.0)

• Identificador NVT: 1.3.6.1.4.1.25623.1.0.103046
• Vector CVSS v3.1: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H (Puntuación: 10.0 - Crítica)
• Análisis Técnico: En las versiones de Samba 3.0.0 a 3.0.25rc3, cuando se activa la directiva de configuración 'username map script', los nombres de usuario suministrados durante la conexión MS-RPC/SMB son pasados sin saneamiento a un intérprete /bin/sh. Un atacante puede concatenar comandos de consola mediante metacaracteres de shell (ej. `nohup command &`), ejecutando código arbitrario con privilegios de superusuario root de forma inmediata.

5.3. UnrealIRCd Backdoor Trojan Execution (CVE-2010-2075 - CVSS 10.0)

• Identificador NVT: 1.3.6.1.4.1.25623.1.0.103186
• Vector CVSS v3.1: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H (Puntuación: 10.0 - Crítica)
• Análisis Técnico: De forma análoga al caso de vsftpd, el paquete de distribución de UnrealIRCd 3.2.8.1 fue troyanizado en 2009. El servidor intercepta los mensajes que ingresan al puerto 6667; si una cadena inicia con los bytes 'AB;', el demonio ejecuta todo el texto subsecuente mediante la función system() del sistema operativo anfitrión, entregando una sesión interactiva al atacante.

5.4. Puerta Trasera Ingreslock en Puerto 1524 (CWE-284 - CVSS 10.0)

• Identificador NVT: 1.3.6.1.4.1.25623.1.0.100074
• Clasificación: CWE-284 (Improper Access Control) | Puntuación: 10.0 (Crítica)
• Análisis Técnico: En Metasploitable 2, el puerto 1524/tcp (asociado históricamente al servicio Ingreslock) está configurado en /etc/inetd.conf para enlazar cualquier conexión entrante con /bin/sh. No requiere autenticación ni explotación de desbordamiento; una conexión TCP trivial (como `nc 192.168.100.5 1524`) otorga inmediatamente una shell interactiva con permisos de root.

5.5. Exposición de Bases de Datos con Credenciales Nulas o Débiles (MySQL y PostgreSQL)

• MySQL (3306/tcp - CVSS 9.8): El motor escucha en todas las interfaces de red (0.0.0.0) y la cuenta administrativa 'root' carece de contraseña. Esto permite la lectura de todas las bases de datos y la escritura de archivos en disco (mediante SELECT ... INTO OUTFILE) para sembrar web shells en el directorio web de Apache.
• PostgreSQL (5432/tcp - CVSS 9.0): Expone el usuario por defecto 'postgres' con contraseña 'postgres'. A través de funciones definidas por el usuario (UDF) en bibliotecas compartidas (.so), es factible ejecutar comandos del sistema operativo como superusuario.

5.6. Consola Tomcat Manager con Credenciales Predeterminadas (CVE-2009-3548 - CVSS 9.8)

• Análisis Técnico: Apache Tomcat 5.5 (puerto 8180/tcp) tiene habilitada la aplicación '/manager/html'. OpenVAS detectó mediante su módulo de credenciales que la cuenta 'tomcat' posee la contraseña de fábrica 'tomcat' con rol de administrador. Este vector permite a un atacante subir un archivo comprimido Java Web Archive (.war) con una shell inversa empacada y desplegarla, obteniendo ejecución remota.





6. Mapeo Metodológico: MITRE ATT&CK for Enterprise y NIST SP 800-115

Para elevar el valor técnico del reporte pericial, se correlacionaron los hallazgos de OpenVAS contra la matriz internacional MITRE ATT&CK for Enterprise y la metodología de evaluación técnica de seguridad NIST SP 800-115 (Sección 4.3: Vulnerability Scanning):

Táctica MITRE ATT&CK	Técnica / Subtécnica	Vector / NVT OpenVAS	Correlación Operativa en Metasploitable 2
TA0043: Reconnaissance	T1595.002: Vulnerability Scanning	OpenVAS / GVM Full & Fast Scan	Ejecución automatizada de sondas activas contra los 23 puertos abiertos en Metasploitable 2.
TA0001: Initial Access	T1190: Exploit Public-Facing Application	Samba CVE-2007-2447 Tomcat /manager/html	Explotación de servicios expuestos perimetralmente para lograr compromiso sin credenciales válidas.
TA0001: Initial Access	T1078.001: Default Accounts	Tomcat (tomcat:tomcat) PostgreSQL (postgres:postgres)	Ingreso no autorizado mediante cuentas administrativas predeterminadas no saneadas tras la instalación.
TA0002: Execution	T1059.004: Unix Shell	vsftpd 2.3.4 (6200/tcp) Ingreslock (1524/tcp)	Ejecución directa de intérpretes de comandos interactivos (/bin/sh) a través de sockets de red descubiertos.
TA0005: Defense Evasion	T1562.001: Disable Tools / Controls	R-Services con .rhosts '+'	Bypass de los mecanismos de autenticación y control de acceso mediante relaciones de confianza no restringidas.
TA0007: Discovery	T1046: Network Service Discovery	GSA Port Inventory (23 puertos)	Mapeo exhaustivo de banners y versiones de software para seleccionar vectores de explotación dirigidos.





7. Matriz Pericial de Riesgos y Plan de Remediación Defensiva (Hardening)

El propósito supremo de una evaluación de vulnerabilidades en pentesting radica en proporcionar una guía técnica precisa y priorizada para mitigar las brechas antes de que puedan ser explotadas por actores hostiles. A continuación se formula la matriz pericial de remediación defensiva bajo el estándar CVSS v3.1:

Vulnerabilidad Auditada	Puertos Afectados	Severidad CVSS	Prioridad	Acción Correctiva de Remediación (Hardening)
Samba 'username map script' (CVE-2007-2447)	139, 445/tcp	10.0 (CRÍTICA)	Inmediata (Horas)	Actualizar Samba a versión >= 3.0.25a. En /etc/samba/smb.conf, comentar o eliminar la directiva 'username map script' y reiniciar el servicio.
vsftpd 2.3.4 Backdoor (CVE-2011-2523)	21/tcp	10.0 (CRÍTICA)	Inmediata (Horas)	Desinstalar el paquete comprometido vsftpd 2.3.4 e instalar la versión oficial corregida >= 2.3.5 desde repositorios autenticados.
Backdoor Ingreslock	1524/tcp	10.0 (CRÍTICA)	Inmediata (Horas)	Editar /etc/inetd.conf o /etc/xinetd.d/, comentar o borrar la entrada del puerto 1524 y reiniciar el superdemonio inetd. Bloquear puerto en iptables.
UnrealIRCd Backdoor (CVE-2010-2075)	6667/tcp	10.0 (CRÍTICA)	Inmediata (Horas)	Detener el servicio UnrealIRCd. Descargar e instalar la versión limpia 3.2.8.2 verificando la firma criptográfica PGP oficial.
R-Services no autenticados	512-514/tcp	9.8 (CRÍTICA)	Corto Plazo (1-2 días)	Deshabilitar los demonios rshd, rlogind y rexecd. Eliminar los archivos ~/.rhosts y /etc/hosts.equiv. Migrar toda la gestión a OpenSSH.
MySQL sin contraseña de root	3306/tcp	9.8 (CRÍTICA)	Corto Plazo (1-2 días)	Ejecutar el script 'mysql_secure_installation'. Asignar contraseña robusta a 'root'. Configurar 'bind-address = 127.0.0.1' en my.cnf.





Vulnerabilidad Auditada	Puertos Afectados	Severidad CVSS	Prioridad	Acción Correctiva de Remediación (Hardening)
Tomcat con credenciales por defecto	8180/tcp	9.8 (CRÍTICA)	Corto Plazo (1-2 días)	Editar tomcat-users.xml cambiando las claves de 'tomcat' y 'admin'. Restringir el acceso al Endpoint /manager por listas de control de acceso.
Telnet en texto plano	23/tcp	7.5 (ALTA)	Mediano Plazo (1 semana)	Desactivar y desinstalar el demonio telnetd. Utilizar exclusivamente SSH (puerto 22) configurado con llaves públicas Ed25519.



Boulevard Tecnológico de Progreso SN x 62, Progreso, Yucatán,
C.P. 97320 Tel. 969 934 3023 E-mail: dir01_dprogreso@tecnm.mx
www.progreso.tecnm.mx



8. Conclusiones

Al realizar esta práctica de escaneo con OpenVAS sobre la máquina virtual Metasploitable 2 entendí la gran diferencia que existe entre un simple escaneo de puertos y una auditoría formal de vulnerabilidades. Antes solía pensar que con Nmap era suficiente para saber si un servidor era seguro, pero al ver a OpenVAS en acción me di cuenta de cómo el escáner interroga a fondo cada servicio, analiza las respuestas de red y las compara contra miles de firmas NVTs para encontrar fallas exactas. Ver que una sola máquina arrojó 18 vulnerabilidades críticas con calificación de 10.0 —como la puerta trasera de vsftpd que se abre con una simple carita feliz o el fallo de Samba que permite tomar control total como root— me demostró que dejar servicios desactualizados o con contraseñas de fábrica es sumamente peligroso.

Lo que más me llamó la atención fue el aprovechamiento de las gráficas y estadísticas que genera Greenbone Security Assistant. Tener el gráfico circular de severidades, la distribución de fallas por cada puerto y el desglose de puntajes CVSS facilita mucho entender qué áreas del servidor son las más urgentes de atender. Además, hacer el ejercicio de mapear los hallazgos contra las tácticas de MITRE ATT&CK me ayudó a ver el panorama completo de cómo un atacante real usaría esas debilidades para entrar, ejecutar comandos y evadir controles.

Me quedo con la lección de que en el pentesting la meta final nunca es solo encontrar fallas o presumir accesos, sino saber explicar el riesgo y proponer soluciones claras de mitigación. Como futuro ingeniero en sistemas, aprendí que elaborar una matriz de remediación con acciones concretas de hardening — como cerrar puertos innecesarios, cambiar credenciales predeterminadas y parchar servicios vulnerables — es el verdadero aporte profesional que debemos dar para proteger los sistemas y la información de cualquier organización.



Boulevard Tecnológico de Progreso SN x 62, Progreso, Yucatán,
C.P. 97320 Tel. 969 934 3023 E-mail: dir01_dprogreso@tecnm.mx
www.progreso.tecnm.mx



9. Referencias Bibliográficas

FIRST.org. (2019). Common Vulnerability Scoring System v3.1: Specification Document. Forum of Incident Response and Security Teams. https://www.first.org/cvss/v3.1/specification-document

Greenbone Networks GmbH. (2024). Greenbone Vulnerability Management (GVM) Architecture and User Documentation. Greenbone Community. https://docs.greenbone.net/

MITRE Corporation. (2024). Common Vulnerabilities and Exposures (CVE) Database: CVE-2007-2447, CVE-2011-2523, CVE-2010-2075. The MITRE Corporation. https://cve.mitre.org/

National Institute of Standards and Technology [NIST]. (2008). Technical Guide to Information Security Testing and Assessment (NIST Special Publication 800-115). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-115

Rapid7. (2023). Metasploitable 2 Exploitability Guide and System Architecture. Rapid7 Documentation. https://docs.rapid7.com/metasploit/metasploitable-2/



Boulevard Tecnológico de Progreso SN x 62, Progreso, Yucatán,
C.P. 97320 Tel. 969 934 3023 E-mail: dir01_dprogreso@tecnm.mx
www.progreso.tecnm.mx